

AI Governance Case Study — Banking Customer Support Chatbot

Project Overview

This project presents an end-to-end AI Governance assessment for a retail banking customer support chatbot leveraging a third-party Large Language Model (LLM). The objective of the assessment was to evaluate governance maturity, identify AI-specific operational and compliance risks, design governance controls, and align the operating model to recognized AI governance principles.

The chatbot was designed to support:

- Account balance queries
- Transaction history requests
- Loan management inquiries
- Card blocking and support
- Investment product guidance
- Customer service FAQs

The assessment focuses on:

- AI risk identification
- Governance and control design
- Human oversight mechanisms
- Data protection controls
- Third-party AI vendor governance
- Residual risk analysis
- Monitoring and governance metrics
- Framework alignment with NIST AI RMF

1. System Architecture Overview

Key Components

1. Customer Interaction Interface
2. Foundation Model / LLM Service
3. AI Orchestration Layer
4. Internal Banking API Gateway
5. Enterprise Data Layer
6. Customer Information Database
7. Audit & Conversation Logging Repository
8. Human-in-the-Loop (HITL) Escalation Workflow

2. Sensitive Data Categories

The chatbot processes multiple forms of regulated and sensitive banking information:

Data Type	Risk Area
Personally Identifiable Information (PII)	Privacy exposure
Authentication Credentials	Unauthorized access
Account Numbers	Financial fraud
Transaction History	Financial privacy
Credit Card Information	PCI compliance
Investment Suitability Data	Regulatory exposure
Chat Conversation Logs	Data leakage risk
Device/IP Metadata	Privacy & tracking concerns

3. AI Risk Register

Risk ID	Risk Description	Likelihood	Impact	Risk Owner	Severity
AI-01	Third-party LLM provider retains or processes customer PII and financial data sent in prompts, causing a data breach or regulatory violation	Medium	High	Chief Information Security Officer	High
AI-02	Chatbot generates factually incorrect or hallucinated responses about account balances, loan terms, or investment products, leading to customer financial harm	Medium	High	Head of AI / Product	High
AI-03	Chatbot executes irreversible actions without sufficient customer authentication or confirmation, causing unintended account disruption	Low	High	Head of Operations	High

Risk ID	Risk Description	Likelihood	Impact	Risk Owner	Severity
AI-04	Conversation logs accumulate unredacted PII and financial data indefinitely, violating DPDP Act data minimisation and retention obligations	High	Medium	Data Protection Officer	High
AI-05	Escalation triggers are poorly defined, causing the chatbot to handle complex complaints or investment advice requests that legally require a human agent	Medium	Medium	Compliance Officer	Medium
AI-06	LLM provider or internal API outage causes chatbot downtime, degrading customer service availability and violating service continuity expectations	Low	Medium	Head of IT Infrastructure	Medium
AI-07	Customers are not clearly informed they are interacting with an AI system, reducing transparency and customer trust	Low	Low	Chief Compliance Officer	Low

4. Governance Controls

Risk ID	Control Name	Control Type	Control Description
AI-01	PII Redaction Filter	Preventive	Detect and mask sensitive customer identifiers before prompt transmission to external LLM services
AI-02	API-Grounded Responses	Preventive	LLM generates conversational language while authoritative banking APIs provide factual financial data
AI-04	Auto Log Deletion Policy	Preventive	Conversation logs automatically purged after approved retention periods aligned with regulatory requirements
AI-05	Hardcoded Escalation Rules	Preventive	Investment, complaint, and fraud-related queries are automatically escalated to human agents

5. Framework Alignment

Control Name	Governance Objective	Framework Alignment
PII Redaction Filter	Prevent exposure of sensitive customer data to external AI providers	NIST AI RMF – MANAGE, Privacy by Design
API-Grounded Responses	Ensure chatbot responses are reliable and traceable to authoritative banking systems	NIST AI RMF – MANAGE, System Reliability & Output Integrity
Auto Log Deletion Policy	Ensure personal data is not retained beyond its defined legal purpose	NIST AI RMF – GOVERN & MANAGE, Data Minimisation
Hardcoded Escalation Rules	Maintain mandatory human oversight for all high-risk customer interactions	NIST AI RMF – GOVERN & MANAGE, Human Oversight

6. Residual Risk Analysis

Risk	Existing Controls	Residual Risk	Residual Risk Rating
PII leakage to LLM provider	PII Redaction Filter + outbound payload inspection	Obfuscated or previously unseen sensitive data patterns may bypass detection mechanisms	Medium
AI hallucination in responses	API-grounded response architecture	LLM may still generate misleading narrative language around correct figures	Medium
Excess PII retained in logs	Automated retention enforcement	Legacy logs or failed deletion jobs may persist until detected through monitoring or audit activities	Low
Regulated query handled without human review	Hardcoded escalation rules	Edge-case queries may fall outside predefined escalation logic or classification thresholds	Medium

7. Governance Operating Model

Governance Activity	Responsible Team / Role
Model approval	AI Review Board + Chief Risk Officer
AI risk assessment	AI Governance Team + Risk Management Team

Governance Activity	Responsible Team / Role
Prompt monitoring	CISO Team + IT Security Team
Incident response	CISO + Compliance Officer + IT Operations
Periodic governance review	AI Governance Team + Internal Audit
Compliance validation	Compliance Officer + Legal Team
Human escalation review	Customer Service Head + Compliance Officer
Vendor risk review	Procurement Team + Third-Party Risk Manager
Data retention audit	Data Protection Officer + IT Operations
Model performance review	Head of AI / Product + Quality Assurance Team
Customer complaint review	Customer Service Head + Compliance Officer
Bias and fairness testing	AI Ethics Team + Head of AI

8. Governance Monitoring Metrics

Control / Area	Metric / KPI	Monitoring Frequency
PII Redaction Filter	Percentage of outbound prompts blocked for containing sensitive data	Weekly
AI Response Accuracy	Hallucination rate measured against authoritative banking APIs	Daily
Escalation Rules	Percentage of regulated queries correctly routed to human agents	Weekly
Outbound Payload Scanner	False positive rate for legitimate prompts incorrectly blocked	Weekly
Vendor SLA Compliance	Number of SLA breaches in uptime or latency commitments	Monthly
Log Deletion Policy	Number of failed automated deletion jobs	Weekly
Incident Management	Number of unresolved AI-related incidents beyond defined SLA thresholds	Daily
Data Retention Audit	Percentage of logs exceeding approved retention periods	Quarterly

Control / Area	Metric / KPI	Monitoring Frequency
Human Escalation Review	Average resolution time for escalated customer queries	Monthly
Model Performance Review	Overall chatbot accuracy rate across all query categories	Monthly

9. Executive Summary

This assessment evaluated the governance posture of an AI-powered customer support chatbot deployed by a retail bank, leveraging a third-party Large Language Model to handle customer queries across account services, transactions, loan management, card operations, and investment products.

The system was assessed across key components including the LLM layer, internal banking APIs, conversation log store, and human escalation workflows.

Seven major risks were identified across the operating environment, with third-party PII leakage, AI hallucination in financial responses, and unauthorized execution of irreversible actions classified as high-impact governance concerns.

Governance controls were designed across preventive, detective, and corrective categories, including:

- PII redaction controls
- API-grounded response architecture
- automated log retention enforcement
- mandatory human escalation mechanisms

The governance framework was aligned to the NIST AI Risk Management Framework across the GOVERN, MANAGE, and MEASURE functions, while also considering India-specific regulatory expectations under the DPDP Act and banking-sector operational risk obligations.

Residual risk across assessed control domains was reduced to Medium-to-Low levels through layered governance controls, though continuous monitoring, periodic vendor reassessment, and ongoing human oversight remain essential to maintaining governance effectiveness.

The assessment concludes that AI-enabled customer support can operate within an acceptable risk posture when supported by:

- strong governance accountability,
- operational controls,
- continuous monitoring,
- and clearly defined human oversight boundaries.

10. Key Governance Learnings

Major Governance Themes

- AI risk cannot be fully eliminated; it must be continuously governed.
 - Human oversight remains essential for regulated customer interactions.
 - Third-party AI vendors create significant accountability and auditability concerns.
 - AI governance requires cross-functional ownership across Risk, Security, Compliance, Operations, and Product teams.
 - Continuous monitoring and measurable KPIs are critical for governance maturity.
-

11. Interview Talking Points

Key Areas Discussed During This Project

- AI governance operating models
 - AI risk assessment methodology
 - Residual risk analysis
 - Human-in-the-loop governance
 - AI incident response workflows
 - Third-party AI vendor governance
 - AI monitoring metrics and KPIs
 - NIST AI RMF alignment
 - Responsible AI oversight
 - Governance tradeoffs between innovation and risk
-

12. Sample Executive-Level Governance Statements

- “AI risk cannot be eliminated completely; it must be continuously governed.”
 - “Compensating controls reduce risk but do not replace accountability.”
 - “The regulator holds the bank accountable, not the chatbot.”
 - “The goal is not a risk-free system, but a governed system where risks are known, measured, and controlled.”
 - “Give the business speed where it is safe. Hold the line where it is not.”
-

13. GitHub README Content

AI Governance Assessment — Banking Customer Support Chatbot

Project Summary

This project demonstrates an end-to-end AI Governance assessment conducted for a retail banking customer support chatbot powered by a third-party Large Language Model (LLM).

The assessment focused on:

- AI risk identification
 - Governance and control design
 - Human oversight mechanisms
 - Vendor governance
 - Residual risk analysis
 - Monitoring and KPI design
 - Alignment with the NIST AI Risk Management Framework
-

Key Governance Areas Covered

AI Risk Assessment

- Hallucination risk
- Third-party data leakage
- Unauthorized autonomous actions
- Data retention violations
- Escalation governance failures
- Operational resilience risks

Governance Controls

- PII redaction mechanisms
- API-grounded response architecture
- Automated retention enforcement
- Human-in-the-loop escalation workflows
- Outbound payload inspection
- Governance monitoring metrics

Governance Framework Alignment

- NIST AI RMF — GOVERN
- NIST AI RMF — MANAGE
- NIST AI RMF — MEASURE
- Privacy by Design

- Human Oversight
 - Vendor Risk Governance
-

Governance Deliverables Included

- AI Risk Register
 - Governance Control Matrix
 - Residual Risk Analysis
 - Governance Operating Model
 - AI Monitoring Metrics
 - Executive Summary
 - Interview Defense Preparation
-

Skills Demonstrated

- AI Governance
 - AI Risk Management
 - Responsible AI
 - AI GRC
 - Third-Party Risk Management
 - Governance Framework Mapping
 - AI Incident Response
 - Residual Risk Analysis
 - Governance Metrics & KPIs
 - Executive-Level Risk Communication
-

Project Outcome

The assessment concluded that AI-enabled banking support systems can operate within an acceptable risk posture when supported by:

- layered governance controls,
 - operational monitoring,
 - human oversight,
 - and continuous governance assurance.
-

Suggested GitHub Repository Structure

```
AI-Governance-Banking-Chatbot/  
|
```

```
|— README.md
|— architecture-overview.md
|— risk-register.md
|— governance-controls.md
|— framework-alignment.md
|— residual-risk-analysis.md
|— governance-operating-model.md
|— monitoring-kpis.md
|— executive-summary.md
└— interview-defense-prep.md
```

14. LinkedIn Project Description

Designed and documented an end-to-end AI Governance assessment for a retail banking customer support chatbot powered by a Large Language Model (LLM).

The project included:

- AI risk assessment
- governance control design
- human-in-the-loop oversight workflows
- third-party AI vendor governance
- residual risk analysis
- governance monitoring KPIs
- alignment with the NIST AI Risk Management Framework

Developed governance deliverables including:

- AI Risk Register
- Governance Control Matrix
- Governance Operating Model
- Executive Summary
- AI Incident Response Workflow

The assessment focused on balancing AI innovation with regulatory compliance, operational resilience, and customer trust within a banking environment.

15. Suggested Resume Bullet Points

- Conducted AI Governance assessment for an LLM-powered banking customer support chatbot.
- Designed governance controls for hallucination risk, third-party data leakage, and human oversight enforcement.

- Developed AI risk register, residual risk analysis, and governance monitoring KPIs.
 - Mapped governance controls to the NIST AI Risk Management Framework (GOVERN, MANAGE, MEASURE).
 - Designed governance workflows for AI incident response, escalation handling, and vendor risk oversight.
 - Created executive-level governance reporting and risk communication documentation.
-

16. Conclusion

This project demonstrates how AI Governance programs can operationalize responsible AI principles within regulated banking environments.

The assessment integrates:

- governance frameworks,
- operational risk management,
- AI control design,
- monitoring mechanisms,
- and accountability structures

to establish a practical governance model for enterprise AI deployment.

The case study highlights that successful AI adoption is not solely dependent on technical capability, but on the organization's ability to govern AI systems responsibly through measurable controls, oversight mechanisms, and continuous assurance activities.